

PENETRATION TESTING REPORT

Mediroza General Hospital

Assessment type	Black-box penetration test and vulnerability assessment
Authorised target	https://medirozahospital.com
Engagement period	Week 4 internship exercise
Prepared for	Networkwalks Instructor
Classification	Confidential - authorised training exercise

This report records authorised testing only. It must not be used as a guide for unauthorised activity.

Contents

Section	Title
1	Executive Summary
2	Scope and Methodology
3	Findings and Proof of Exploitation
4	Risk Rating
5	Recommendations and Remediation
6	Conclusion and Evidence Handling

The report is arranged around the required assessment structure. Evidence references are presented in a privacy-preserving form; raw reports, passwords, SQL data, and identity-bearing screenshots are not included in this submission copy.

1 Executive Summary

An authorised black-box assessment of Mediroza General Hospital identified a critical chain of weaknesses that exposed patient, employee, and corporate information. The initial weakness was a patient-portal login that revealed whether usernames existed and was vulnerable to SQL injection. The resulting unauthorised portal access exposed three encrypted patient laboratory reports. Their passwords were weak enough to be recovered using wordlists.

The third recovered report contained metadata that pointed to a legacy server location. That location was configured with directory listing enabled and exposed a database backup. The backup contained confidential staff compensation and shareholder information in plaintext. The combined impact is severe because a low-complexity external attack path led from unauthenticated access to multiple categories of regulated and commercially sensitive data.

Overall risk

Overall risk is assessed as Critical. The vulnerabilities are externally reachable, can be chained without valid credentials, and provide access to identifiable health information, salary data, and shareholder information. Immediate containment and a credential/access review are recommended.

Key findings

ID	Finding	Rating	Business impact
F-01	Username enumeration	Medium	Supports account targeting and improves attack efficiency.
F-02	SQL injection login bypass	Critical	Enables unauthorised access to a restricted portal.
F-03	Patient reports accessible after bypass	High	Discloses identifiable laboratory information.
F-04	Weak PDF passwords	High	Encryption is defeated with wordlists.
F-05	Sensitive PDF metadata	Medium	Reveals an internal clue leading to further exposure.
F-06	Legacy directory listing and backup exposure	Critical	Allows unauthenticated download of a database backup.
F-07	Plaintext salaries and ownership data in backup	Critical	Discloses high-impact employee and corporate data.

2 Scope and Methodology

2.1 Scope

Item	Detail
Target	https://medirozahospital.com
Assessment model	Authorised black-box testing
Permitted work	Reconnaissance, web-application testing, report recovery, encryption analysis, metadata review and exposure analysis
Restrictions	Testing limited to the target domain. No social engineering, denial of service, or out-of-scope systems.
Deliverables	Evidence of access and report recovery; documented exposure; readable confidential-data summary; professional report.

2.2 Methodology

The assessment followed a focused progression from reconnaissance to validation, impact analysis, and reporting. Each step was performed only within the exercise authorisation and stopped once sufficient evidence had been obtained to establish impact.

Phase	Activity	Outcome
Reconnaissance	Reviewed public application hints and identified accessible paths.	Located the patient portal and legacy path.
Authentication testing	Compared login responses and tested input handling.	Confirmed account enumeration and SQL injection behaviour.
Access validation	Validated restricted-content exposure after authorised bypass.	Recovered three confidential reports.
File analysis	Assessed PDF protection and inspected decrypted metadata.	Recovered report content and identified the legacy-backup clue.
Exposure analysis	Reviewed accessible legacy content and database-backup risk.	Confirmed exposure of staff and shareholder data categories.

2.3 Tools and techniques

The assessment used a web browser and HTTP requests for reconnaissance and application review, NetworkWalks Hash Calculator , NetworkWalks Password Cracker, and metadata inspection for document properties. No automated exploitation was required beyond the exercise-approved validation steps.

2.4 Limitations

Testing was time-boxed and limited to the defined web domain. No social engineering, availability testing, lateral movement, source-code review, infrastructure scanning beyond the stated exercise, or destructive actions were performed. The report rates demonstrated impact, not the total possible impact across the hospital environment.

3 Findings and Proof of Exploitation

The findings form a single attack path. The evidence below records the observations required to support each conclusion while excluding patient identifiers, passwords, raw database content, and exploit strings from this shareable report.

3.1 Attack path

Step	Observed condition	Result
1	Public crawl guidance identified non-indexed application paths.	Patient portal and legacy directory became discoverable.
2	The login page disclosed different errors for unknown and known usernames.	Valid account existence could be inferred.
3	Unsafe database error behaviour was observed during input testing.	Authentication control was bypassed in the authorised exercise.
4	Portal content listed three password-protected patient reports.	Reports were obtained for permitted recovery testing.
5	Passwords were recovered from wordlists and files were decrypted.	Confidential clinical data and metadata became readable.
6	Metadata referenced a legacy backup location; the location was browsable.	A database backup became visible and downloadable.
7	Backup tables held salary and shareholder fields in plaintext.	Critical employee and corporate data exposure was established.

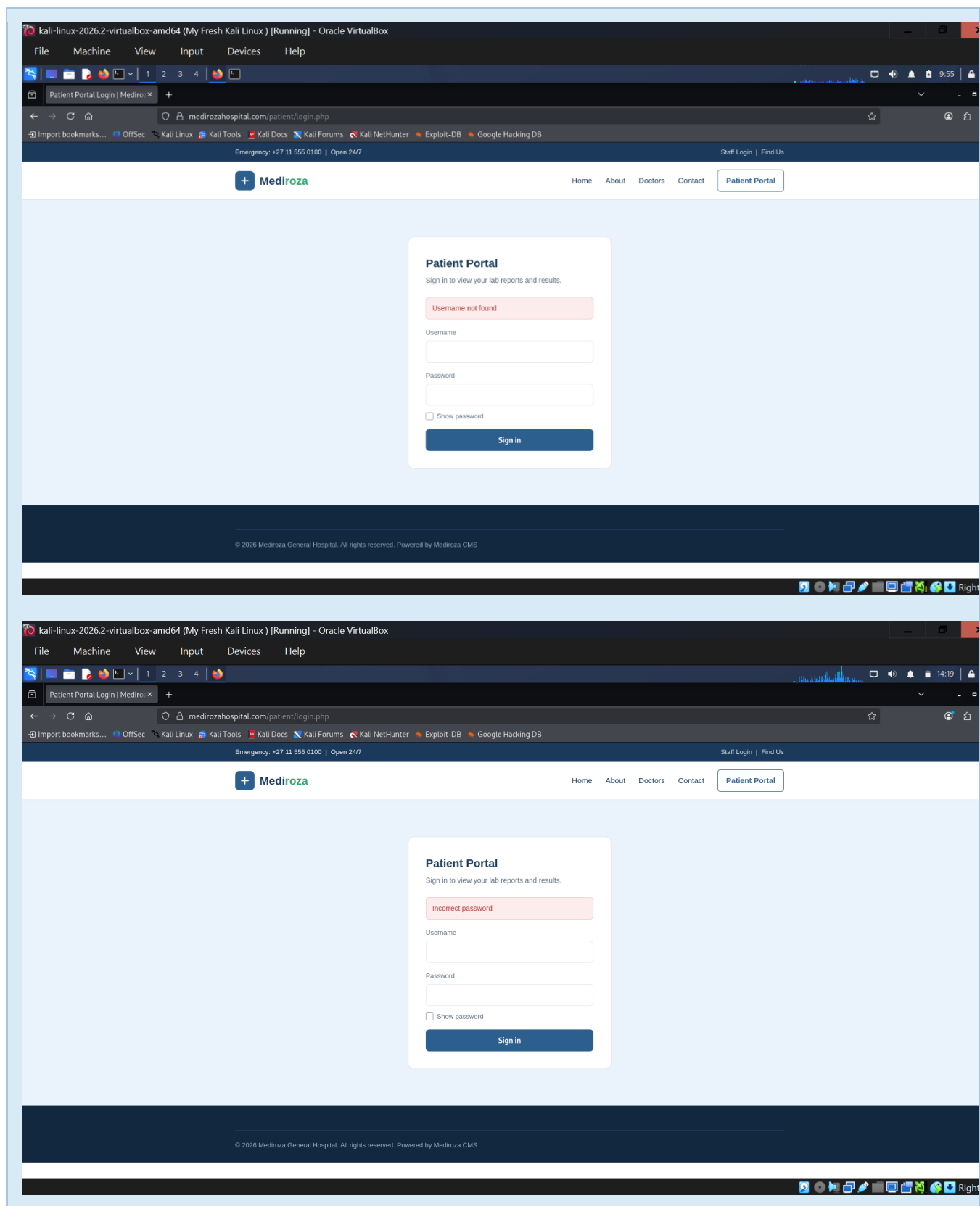
F-01 Username enumeration

Rating	Location	Affected area
Medium	/patient/login.php	External web application

The patient portal returned distinct messages for an unknown account and a known account with an incorrect password. This disclosed whether a submitted username was valid.

Evidence observed

A test using a non-existent username produced a user-not-found response. A test using a known account name produced an incorrect-password response. The difference established account enumeration.



Impact: Attackers can build a valid-account list before attempting credential attacks, reducing uncertainty and increasing the likelihood of successful compromise.

Recommended action: Return one generic error message for all failed logins, apply rate limiting, and monitor repeated authentication failures.

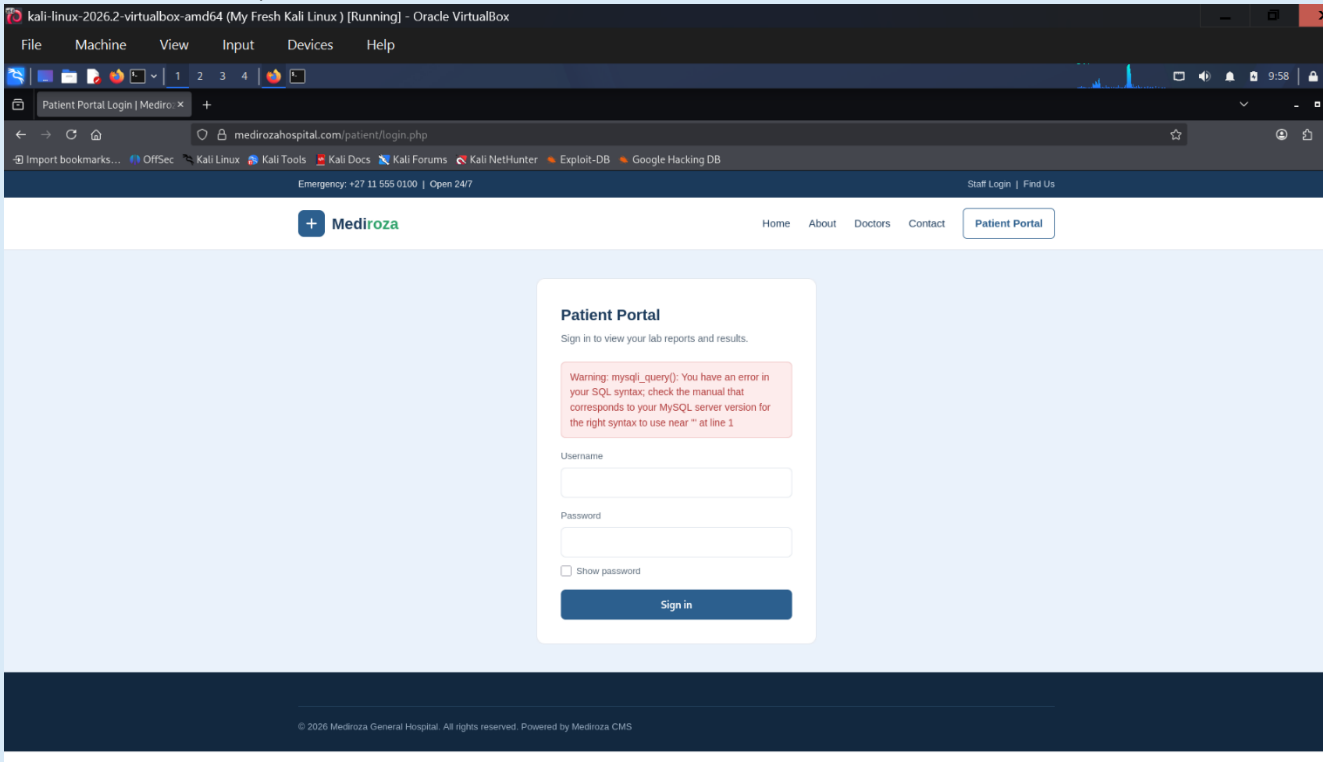
F-02 SQL injection enabled login bypass

Rating	Location	Affected area
Critical	/patient/login.php	External web application

Input handling at the login page exposed database syntax errors and accepted an authorised query-altering input, demonstrating that authentication logic was built from unsafe user-controlled input.

Evidence observed

A malformed username produced a MySQL syntax error. The exercise then verified that the password condition could be bypassed, after which the restricted portal loaded.



The screenshot shows a web browser window with the address bar displaying 'medirozahospital.com/patient/login.php'. The page title is 'Patient Portal Login | Mediroza'. The main content area features a 'Patient Portal' login form with a warning message: 'Warning: mysql_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' at line 1'. The form includes fields for 'Username' and 'Password', a 'Show password' checkbox, and a 'Sign in' button. The footer of the page indicates '© 2016 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS'.

Impact: An unauthenticated attacker could obtain access to restricted portal content and use that access as a starting point for further data exposure.

Recommended action: Replace dynamic SQL concatenation with parameterised queries or prepared statements. Review every database query, add server-side validation, remove verbose database errors, and conduct a focused retest.

F-03 Patient reports accessible after login bypass

Rating	Location	Affected area
High	/patient/reports/	External web application

After the authentication bypass, the portal displayed and allowed retrieval of three confidential laboratory reports. The files contained identifiable personal and clinical information.

Evidence observed

Three encrypted PDF reports were listed in the portal and recovered. Each was successfully opened only after the authorised password-recovery step described in F-04.

Impact: The exposed reports included patient identifiers, dates of birth, referring clinicians, laboratory references, test values, and clinical flags. This constitutes exposure of highly sensitive health data.

Recommended action: Store reports outside the web root, enforce server-side authorisation on every download, use short-lived access controls, and log/report-access events.

F-04 Weak PDF passwords

Rating	Location	Affected area
High	patient_report_1.pdf through patient_report_3.pdf	External web application

The PDF encryption relied on passwords that were recoverable from a common list or a supplied extended wordlist. The encryption therefore did not provide meaningful resistance once the files were obtained.

Evidence observed

All three recovered files were encrypted. The first two passwords were recovered with the built-in word list from the networkwalks password cracker; the third was recovered with an extended password list. Decryption succeeded for every report.

Hash Calculator - Networkwalk: x Password Cracker (Dictionary A x + Ask Gemini

networkwalks.com/password-cracker/

Tried: 1 / 1001000 pw/s1%

[*] Loaded wordlist: built-in list (100 entries)

[*] Target: PDF R3 / 128-bit / dictionary attack

[*] Deriving keys with MD5 + RC4 ...

[+] MATCH 123456 ✓

PASSWORD CRACKED SUCCESSFULLY

123456

This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

PDF HASH (\$PDF\$...)

\$pdf\$2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56ffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6

We Are Here

Hash Calculator - Networkwalk: x Password Cracker (Dictionary A x + Ask Gemini

networkwalks.com/password-cracker/

Tried: 2 / 1000 pw/s2%

[*] Loaded wordlist: built-in list (100 entries)

[*] Target: PDF R3 / 128-bit / dictionary attack

[*] Deriving keys with MD5 + RC4 ...

[+] MATCH password ✓

PASSWORD CRACKED SUCCESSFULLY

password

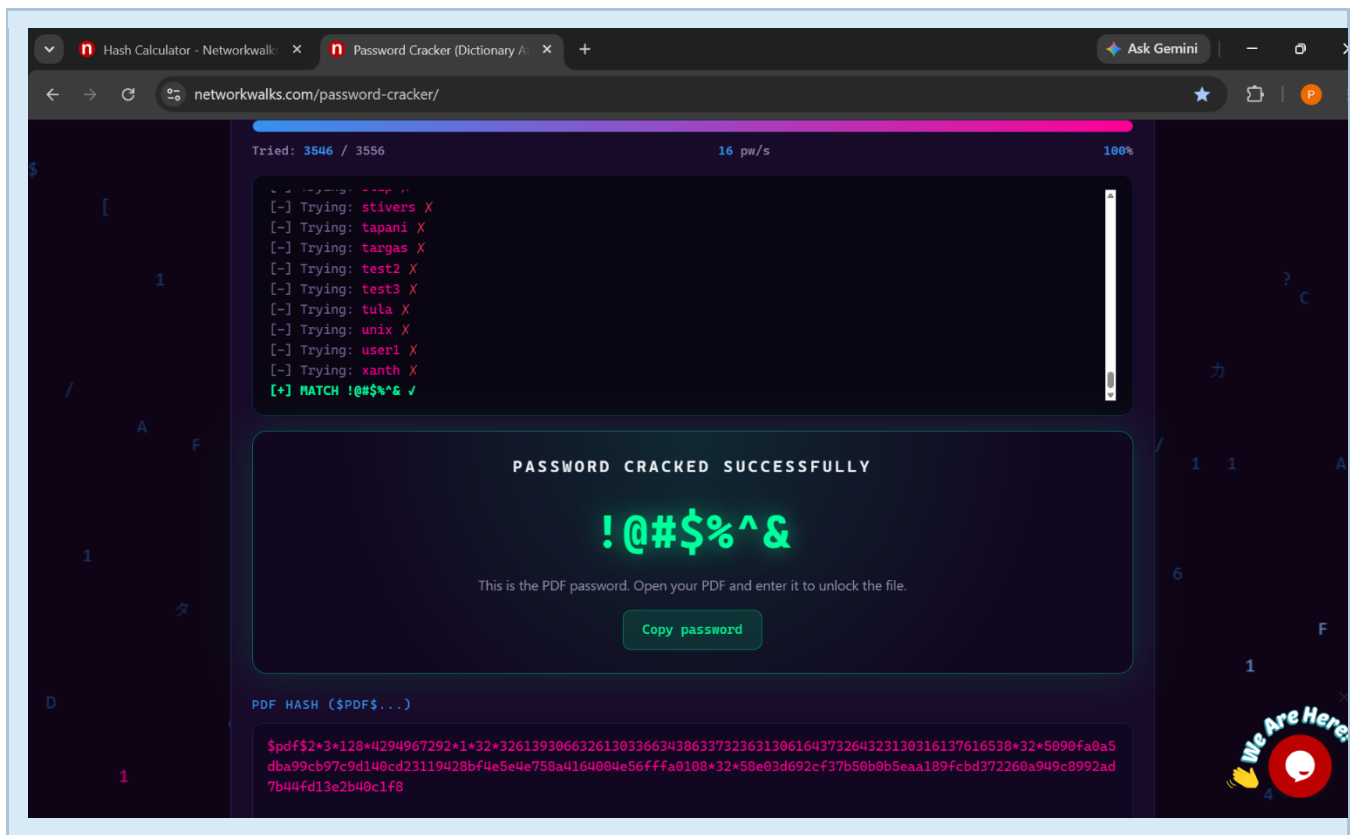
This is the PDF password. Open your PDF and enter it to unlock the file.

Copy password

PDF HASH (\$PDF\$...)

\$pdf\$2*3*128*4294967292*1*32*3166346338373236356437626464363834663737303265633666363264616463*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56ffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775

We Are Here



Impact: A user who obtains a protected report can recover the contents without needing a separate authorised access path. The apparent encryption creates a false sense of security.

Recommended action: Avoid shared or predictable PDF passwords. Prefer authenticated report delivery. If file encryption is unavoidable, use unique high-entropy passwords delivered through a separate trusted channel.

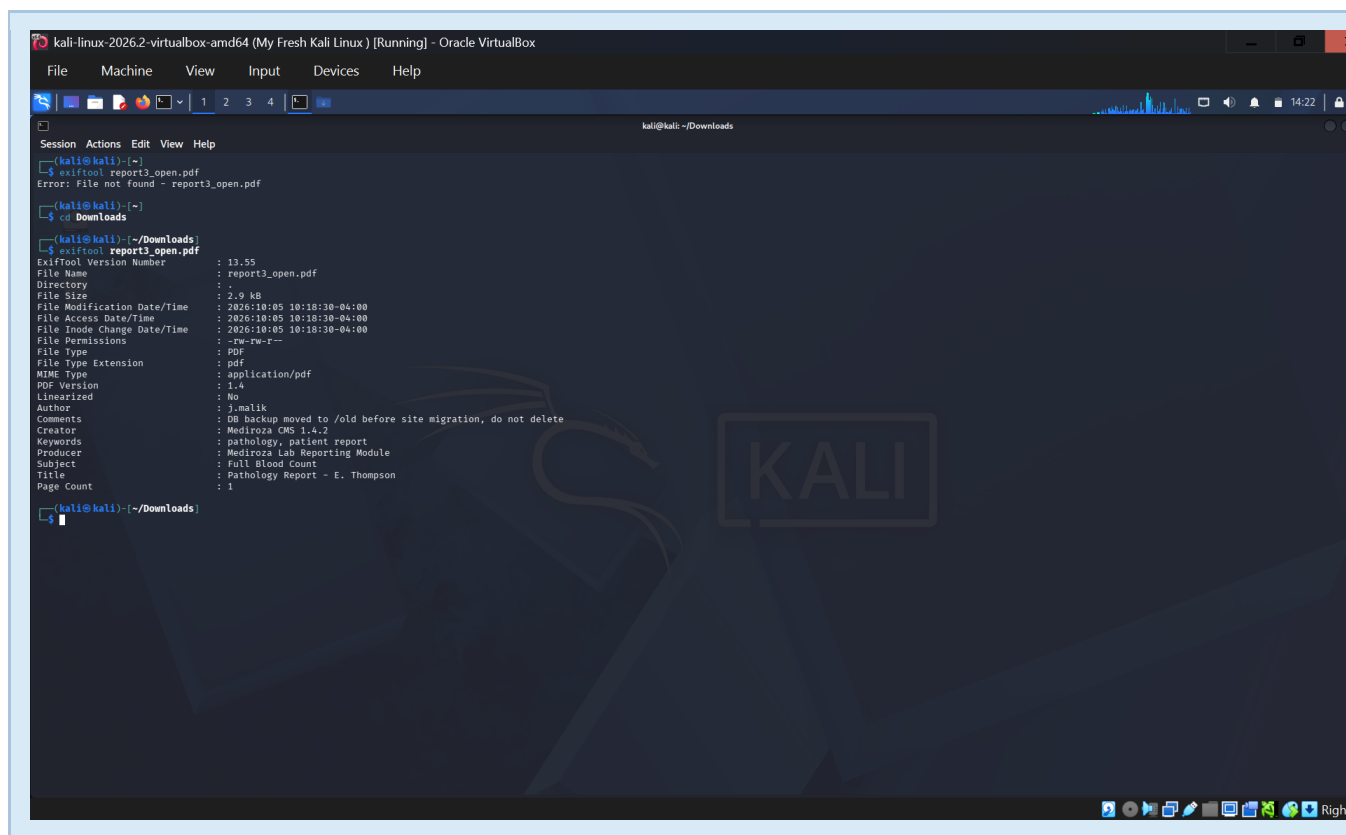
F-05 Sensitive metadata revealed an internal backup clue

Rating	Location	Affected area
Medium	patient_report_3.pdf metadata	External web application

The third report contained operational metadata instead of only document-identification data. The author field pointed to an internal account identifier and the comments field disclosed that a database backup had been moved to a legacy location.

Evidence observed

The decrypted PDF metadata included an internal author identifier and an operational comment referencing a database backup at the legacy path. The clue correlated with the legacy path already visible during reconnaissance.



Impact: Operational information in metadata can turn a limited document disclosure into a route to server-side data. In this case, it materially enabled discovery of the critical backup exposure.

Recommended action: Implement metadata stripping in the document-release process, set approved metadata defaults, and perform a final pre-publication review of generated PDFs.

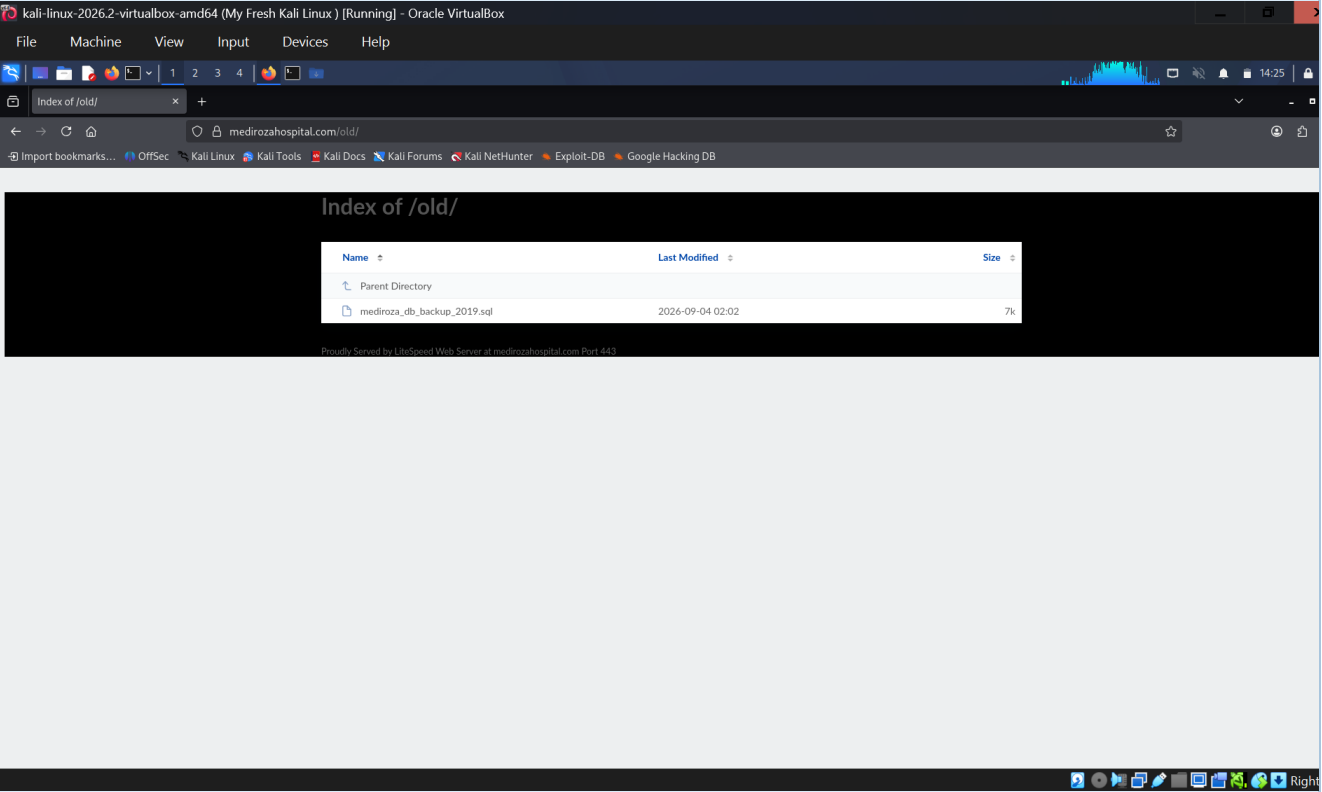
F-06 Directory listing exposed a legacy database backup

Rating	Location	Affected area
Critical	/old/	External web application

The legacy location was configured to display a directory listing. The listing exposed a database-backup file placed under a publicly accessible web path.

Evidence observed

The legacy directory was discoverable through public crawl guidance and document metadata. Browsing the location displayed the backup file `mediroza\_db\_backup\_2019.sql`.



Impact: An unauthenticated party could discover and download a backup that bypasses application-level controls. A backup can contain far broader data than the current application exposes.

Recommended action: Immediately remove the backup from the web server, disable directory indexing, deny access to backup extensions, and run an enterprise-wide search for public backup copies and obsolete directories.

F-07 Plaintext staff salaries and shareholder data in backup

Rating	Location	Affected area
Critical	mediroza_db_backup_2019.sql	External web application

The exposed SQL backup contained staff and shareholder records in plaintext. These tables held salary information and ownership details that should not be publicly available.

Evidence observed

The staff records included employee name, job title, department, email, and monthly salary. The shareholder records included shareholder name, share percentage, and share class. Individual values are withheld from this public report.

kali-linux-2026.2-virtualbox-amd64 (My Fresh Kali Linux) [Running] - Oracle VirtualBox

FileMachineViewInputDevicesHelp

1234

~mediroza_db_backup_2019.sql - Mousepad

FileEditSearchViewDocumentHelp

1 -- mediroza_db_backup_2019.sql
2 -- Mediroza General Hospital - Internal database backup
3 -- Generated by Mediroza CMS 1.4.2 backup module
4 -- Host: localhost Database: mediroza_hr
5 -- WARNING: contains confidential staff and shareholder records
6 -- Backup date: 2019-08-27 02:14:03
7
8 SET NAMES utf8mb4;
9 SET FOREIGN_KEY_CHECKS = 0;
10
11 --
12 -- Table structure for table `staff`
13 --
14 DROP TABLE IF EXISTS `staff`;
15 CREATE TABLE `staff` (
16 `id` int(11) NOT NULL AUTO_INCREMENT,
17 `full\_name` varchar(120) NOT NULL,
18 `job\_title` varchar(120) NOT NULL,
19 `department` varchar(40) NOT NULL,
20 `email` varchar(120) NOT NULL,
21 `phone` varchar(20) NOT NULL,
22 `national\_id` varchar(20) NOT NULL,
23 `monthly\_salary` int(11) NOT NULL,
24 `date\_joined` date NOT NULL,
25 PRIMARY KEY (`id`)
26) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
27
28 --
29 -- Dumping data for table `staff`
30 --
31 LOCK TABLES `staff` WRITE;
32 INSERT INTO `staff` (`id`,`full\_name`,`job\_title`,`department`,`email`,`phone`,`national\_id`,`monthly\_salary`,`date\_joined`) VALUES
33 ((1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 181 2807','85021913011081',138000,'2009-03-16'),
34 (2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031823822082',152000,'2011-07-01'),
35 (3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 181 2021','85041013013083',100000,'2007-01-22'),
36 (4,'Dr. Anita Botha','Consultant Cardiologist','Cardiology','a.botha@medirozahospital.com','+27 82 104 2028','85051843844084',152000,'2012-09-19'),
37 (5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 195 2035','85061053055085',120000,'2013-02-18'),
38 (6,'Dr. Yusuf Cassin','Senior Registrar','Emergency & Trauma','y.cassin@medirozahospital.com','+27 82 186 2042','85071063866086',70000,'2018-05-04'),
39 (7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 189 2049','85081072077087',90000,'2019-11-15'),
40 (8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2050','85091883088088',12000,'2016-08-23'),
41 (9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 189 2063','85101893899089',55000,'2015-04-12'),
42 (10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111811011081',60000,'2017-10-02'),
43 (11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121111121082',34000,'2016-01-19'),
44 (12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011121121083',33000,'2017-06-07'),
45 (13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021131131084',35000,'2015-12-01'),
46 (14,'Zamele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031141141085',42000,'2013-03-25'),
47 (15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041151151086',61000,'2014-09-08'),
48 (16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051161161087',20000,'2019-02-14'),
49 (17,'Themba Mxosi','Radiographer','Radiology','t.mxosi@medirozahospital.com','+27 82 117 2119','85061171171088',44000,'2016-07-30'),
50 (18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071181181089',43000,'2017-04-11'),
51 (19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081191191090',41000,'2015-05-28'),
52 (20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091201201091',35000,'2018-08-06'),
53 (21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101211211093',130000,'2012-02-28'),
54 (22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111221221094',110000,'2013-10-17'),
55 (23,'Aisha Singh','Physiotherapist','Rehabilitation','a.singh@medirozahospital.com','+27 82 123 2161','85121231231095',48000,'2016-11-06'),
56 (24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011241241096',150000,'2011-06-13'),
57 (25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021251251097',52000,'2014-01-27'),
58 (26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031261261098',20000,'2018-03-19'),
59 (27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041271271099',27000,'2019-09-02'),
60 (28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051281281100',20000,'2020-02-18'),
61 (29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061291291102',30000,'2015-08-24'),
62 (30,'Anilika Mkhali','Nurse Clerk','Administration','a.mkhali@medirozahospital.com','+27 82 130 2210','85071301301103',11000,'2013-11-05');
63 UNLOCK TABLES;
64
65 --
66 -- Table structure for table `shareholders`
67 --
68 DROP TABLE IF EXISTS `shareholders`;
69 CREATE TABLE `shareholders` (
70 `id` int(11) NOT NULL AUTO_INCREMENT,
71 `shareholder\_name` varchar(120) NOT NULL,
72 `share\_percent` decimal(2,2) NOT NULL,
73 `shares\_held` int(11) NOT NULL,
74 `share\_class` varchar(20) NOT NULL,
75 PRIMARY KEY (`id`)
76) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
77
78 LOCK TABLES `shareholders` WRITE;
79 INSERT INTO `shareholders` (`id`,`shareholder\_name`,`share\_percent`,`shares\_held`,`share\_class`) VALUES
80 ((1,'Dr. Rajesh Naidoo',10.0,100000,'Ordinary'),
81 (2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
82 (3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
83 (4,'Reddy Family Trust',11.0,110000,'Ordinary'),
84 (5,'Thabo Molefe',10.0,100000,'Ordinary'),
85 (6,'Sarah Botha',8.0,80000,'Ordinary'),
86 (7,'Dr. Ahmed Kara',5.0,50000,'Preferential'),
87 (8,'Naledi Zulu',7.0,70000,'Ordinary'),
88 (9,'Michael Roberts',6.0,60000,'Ordinary'),
89 (10,'Dr. Vikram Chetty',8.0,80000,'Preferential');
90 UNLOCK TABLES;
91
92 SET FOREIGN_KEY_CHECKS = 1;
93 -- End of backup
94

Impact: Disclosure of salary data can cause privacy, employee-relations, fraud, and targeted-social-engineering harm. Disclosure of ownership details can create commercial, governance, and personal-security risk.

Recommended action: Treat the exposure as a potential data breach: preserve logs, assess access, notify stakeholders under the relevant policy and legal process, rotate affected credentials, encrypt backups, and restrict backup access by least privilege.

3.2 Confidential data summary

Staff Information

#	Name	Job Title	Department	Monthly Salary (ZAR)
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R138,000
2	Sarah Botha	Chief Financial Officer	Finance	R152,000
3	Dr. Johan van der Merwe	Medical Director	Management	R160,000
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R132,000
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R128,000
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R74,000
7	Michael Roberts	HR Director	Human Resources	R96,000
8	Susan Pretorius	HR Officer	Human Resources	R32,000
9	Jameel Malik	IT Systems Administrator	IT	R58,000
10	Thabo Molefe	Network Engineer	IT	R46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	R33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	R35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	R42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	R61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	R26,000
17	Themba Nkosi	Radiographer	Radiology	R44,000
18	Palesa Radebe	Radiographer	Radiology	R43,000
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	R41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	R35,000
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R130,000
22	Dr. Fatima Patel	Pediatrician	Pediatrics	R118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	R48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	R135,000
25	David Smith	Facilities Manager	Operations	R52,000
26	Karen O'Connor	Billing Administrator	Finance	R29,000
27	James Wilson	Security Supervisor	Operations	R27,000

28	Linda Fourie	Receptionist	Front Office	R19,000
29	Peter van Wyk	Procurement Officer	Supply Chain	R38,000
30	Andile Mbeki	Ward Clerk	Administration	R21,000

Shareholder Information

#	Shareholder Name	Share Percentage	Share Class
1	Dr. Rajesh Naidoo	18.0%	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	Ordinary
3	Dr. Johan van der Merwe	12.0%	Ordinary
4	Reddy Family Trust	11.0%	Ordinary
5	Thabo Molefe	10.0%	Ordinary
6	Sarah Botha	9.0%	Ordinary
7	Dr. Ahmed Kara	8.0%	Preferential
8	Naledi Zulu	7.0%	Ordinary
9	Michael Roberts	6.0%	Ordinary
10	Dr. Vikram Chetty	4.0%	Preferential

4 Risk Rating

Ratings were assigned using demonstrated impact and likelihood in the context of an externally reachable hospital web application. Critical findings permit unauthenticated access to highly sensitive data or expose it directly. High findings expose protected data after a realistic adjacent weakness or defeat a security control. Medium findings materially assist compromise or disclosure but do not independently expose the full dataset.

Finding	Rating	Likelihood	Impact	Justification
F-01	Medium	High	Moderate	Directly identifies valid accounts but does not grant access alone.
F-02	Critical	High	Severe	Authentication bypass provided restricted portal access without valid credentials.
F-03	High	High after F-02	Severe	Exposed identifiable laboratory reports.
F-04	High	High	Severe	Wordlists defeated document encryption.
F-05	Medium	Moderate	Moderate	Operational clue enabled further compromise but required follow-on action.
F-06	Critical	High	Severe	Public legacy folder disclosed a full database backup.
F-07	Critical	High	Severe	Plaintext salaries and ownership information were present in exposed data.

5 Recommendations and Remediation

Remediation should begin with containment of the exposed backup and restoration of access controls. The hospital should then remove the underlying coding and governance weaknesses that made the exposure possible.

Priority	Action	Owner	Success criteria
Immediate	Remove public backup copies; disable directory listing; block public access to legacy paths and backup extensions.	IT Operations	Legacy directory returns no listing and no backup is web-accessible.
Immediate	Preserve relevant logs, determine whether downloads occurred, and begin incident-response procedures.	Security / Legal	Access review is documented and notifications follow policy.
Immediate	Fix SQL injection using parameterised queries and remove verbose database errors.	Application team	Injection tests fail safely; login continues to work normally.
Near term	Move patient reports outside the web root and require server-side per-record authorisation.	Application team	Unauthorised or direct URL requests cannot retrieve reports.
Near term	Replace PDF password practice with authenticated delivery and unique high-entropy protection when needed.	Clinical systems	Recovered files cannot be opened with common passwords.
Near term	Strip metadata from outbound PDFs and introduce a release checklist.	Clinical systems	Published files contain only approved metadata.
Near term	Standardise failed-login responses and add rate limiting and monitoring.	Application team	Known and unknown usernames produce indistinguishable external responses.
Ongoing	Centralise encrypted backups, limit access by role, and maintain a tested backup inventory.	IT Operations	No backups remain in public paths; inventory and access reviews are current.

5.1 Retest plan

After fixes are deployed, conduct a scoped retest of the patient login, error handling, report-download authorisation, PDF metadata, legacy URLs, directory indexing, backup paths, and web-server configuration. The retest should confirm both that individual findings are fixed and that the demonstrated chain cannot be reproduced.

6 Conclusion

This assessment demonstrated that a series of individually remediable weaknesses combined into a critical data-exposure path. The highest-priority actions are removing the public backup, eliminating SQL injection, and restricting report access. Because the exposed material includes identifiable health information, salaries and ownership data, the organization should treat the issue as an incident requiring prompt technical containment and management review.

Authorisation statement

All actions documented in this report were performed within the Networkwalks Mediroza General Hospital educational exercise and its stated written authorisation. The techniques and observations must not be applied to any system without explicit written permission from the owner.